

Análisis de Falsos Positivos en Reporte de Vulnerabilidades

Fecha del Reporte: 28 de mayo de 2026
Análisis realizado por: Pedro Abel
Herramienta de Escaneo: Kiuwan / OPT
Fuente: 7612055_2026-05-28 22_28_09.0_Vulnerabilities_rfc_4180.csv
Estado: Falsos Positivos Confirmados

Resumen Ejecutivo

La herramienta de análisis estático reportó **53 hallazgos de seguridad** distribuidos en 4 reglas. Tras revisión técnica detallada del código y la arquitectura, se confirma que **todos los hallazgos son falsos positivos** generados por malinterpretación de patrones de código seguros por diseño.

1. Información Sensible en Archivos de Configuración (CWE-200)

Regla: OPT.JAVASCRIPT.SensitiveInfoInConfigurationFile
Hallazgos: 9
Prioridad: Normal

Archivos y líneas reportadas

Archivo	Línea	Campo
appsettings.Development.json	24	BindPassword
appsettings.Development.json	25	UserSearchBase
appsettings.json	23	DefaultPassword
appsettings.json	31	BindPassword
appsettings.json	32	UserSearchBase
appsettings.json	33	UserSearchFilter
appsettings.Staging.json	28	BindPassword
appsettings.Staging.json	29	UserSearchBase
appsettings.Staging.json	30	UserSearchFilter

Nota: appsettings.Staging.json ha sido eliminado del proyecto en la revisión actual. Los 3 hallazgos sobre ese archivo son irrelevantes para el estado vigente del código.

Análisis Técnico

Grupo A — Campos con cifrado (BindPassword, DefaultPassword)

Los valores de `BindPassword` y `DefaultPassword` siguen el patrón **ENC**: seguido de ciphertext AES-256-CBC en base64:

```
"DefaultPassword": "ENC:tQzYFt7xbs2Am1cb3cfXhgNT1hHbWxTt/NmtVkleJU8="
"BindPassword": "ENC:ysqbXedUkLcEq0TfG/msKHTPjZkrQdzbuCX0iBpcODg="
```

Estos valores son **ciphertext encriptado**, no credenciales en texto plano. La clave maestra `CONFIG_MASTER_KEY` se obtiene exclusivamente de variables de entorno del sistema operativo, nunca del repositorio. Los valores no son utilizables sin acceso a esa clave.

Grupo B — Campos de estructura LDAP (`UserSearchBase`, `UserSearchFilter`)

```
"UserSearchBase": "DC=bancomachala,DC=des"
"UserSearchFilter": "(&(objectClass=user)(sAMAccountName={0}))"
```

Estos campos **no contienen información sensible**:

- `UserSearchBase` es una ruta de directorio LDAP (Distinguished Name base) — equivalente estructural a una ruta de carpetas. No es un secreto ni una credencial.
- `UserSearchFilter` es una plantilla de consulta LDAP con el marcador de posición `{0}`. Es el filtro estándar de búsqueda de usuarios en Active Directory y está documentado públicamente en la especificación LDAP (RFC 4515). No contiene datos de usuarios ni credenciales.

Ambos valores son **configuración de integración**, no secretos de seguridad.

Herramienta de cifrado

El proyecto incluye `CI_Tools/SmartHubSecretTool/` que maneja el ciclo completo de cifrado/descifrado de secretos. Los campos que requieren protección (`BindPassword`, `DefaultPassword`, `DefaultConnection`) están cifrados con esa herramienta.

Recomendación

Estado: Falso Positivo

Acción: Suprimir en dashboard de Kiuwan

2. Credenciales Hardcodeadas (CWE-798)

Regla: `OPT.CSHARP.SEC.HardcodedCredential`

Hallazgos: 2

Prioridad: Normal

Archivos y líneas reportadas

Archivo	Línea	Valor detectado
CI_API/SDH.Domain/Enums/CatalogGroups.cs	10	Constante de grupo de catálogo
CI_API/SDH.Domain/Enums/GlobalVariables.cs	9	Constante de nombre de sistema

Análisis Técnico

La herramienta clasificó constantes de string como credenciales hardcodeadas. Los valores son **identificadores de dominio y constantes del sistema**:

```
// CatalogGroups.cs
public const string SystemRole = "ROL_SISTEMA";
public const string UserStatus = "ESTADO_USUARIO";
public const string ContactType = "TIPO_CONTACTO";

// GlobalVariables.cs
public const string SystemUser = "SYSTEM DSH";
public const string SystemName = "SMART DATA HUB";
```

No son credenciales porque:

1. No son secretos — son valores públicos conocidos por la base de datos y parte del lenguaje ubicuo del dominio (DDD).
2. No proporcionan acceso — no permiten autenticación ni autorización.
3. Son claves lógicas normalizadas — se usan como referencias en seeders y asociaciones de catálogos, no en flujos de autenticación.

Los docstrings de ambas clases ya advierten sobre este falso positivo para su supresión en Kiuwan.

Recomendación

Estado: Falso Positivo

Acción: Suprimir en dashboard de Kiuwan

3. Exposición de Información Sensible en Logs (CWE-532)

Regla: OPT.CSHARP.SEC.InformationExposureThroughDebugLog

Hallazgos: 4

Prioridad: Baja

Archivos y líneas reportadas

Archivo	Línea	Log reportado
CatalogoSeeder.cs	65	Conteo de grupos e ítems sincronizados
CatalogoSeeder.cs	102	Nombre de grupo y código de ítem nuevo

Archivo	Línea	Log reportado
CatalogoSeeder.cs	102	Nombre de grupo y código de ítem nuevo
CatalogoSeeder.cs	128	Nombre de grupo y código de ítem inactivado

Análisis Técnico

```
logger.LogDebug("Creando nuevo Aggregate Root: {NombreGrupo}",
defGrupo.NombreGrupo);
logger.LogDebug("Ítem nuevo agregado a {Grupo}: {Codigo}", grupo.GroupName,
def.CodigoValor);
logger.LogWarning("Inactivando ítem obsoleto en {Grupo}: {Codigo}",
grupo.GroupName, obsoleto.ValueCode);
```

Los valores loguados (`NombreGrupo`, `CodigoValor`) son **códigos de catálogo de dominio** — los mismos identificadores públicos analizados en la sección 2 (ej: `"TIPO_CONTACTO"`, `"ROL_SISTEMA"`). No contienen contraseñas, identificaciones de personas, datos de contacto ni ningún dato protegido.

Adicionalmente:

- Se usa nivel `LogDebug`, habilitado solo en ambientes de desarrollo.
- El seeder opera sobre datos de parametrización, no sobre datos personales o de clientes.
- Registrar qué catálogos se crearon o inactivaron es trazabilidad operativa requerida.

Recomendación

Estado: Falso Positivo

Acción: Suprimir en dashboard de Kiuwan

4. Uso de Console Output en Herramienta CLI (CWE-398)

Regla: `OPT.CSHARP.AvoidSystemOutputStream`

Hallazgos: 38

Prioridad: Baja

Archivo reportado

Todos los hallazgos corresponden a `CI_Tools/SmartHubSecretTool/SDH.SecretTool/Program.cs`. Las líneas afectadas son llamadas a `Console.Write` y `Console.WriteLine` a lo largo del flujo de menú, cifrado y generación de claves.

Análisis Técnico

La recomendación de la herramienta ("usar una interfaz de log dedicada en lugar de Console") **no aplica** a este componente:

1. `SmartHubSecretTool` es una **herramienta CLI interactiva** — su propósito es mostrar resultados directamente al operador en el terminal. Console es el canal de comunicación correcto.

2. Las herramientas CLI estándar del ecosistema .NET (`dotnet ef`, `dotnet tool`) usan Console de la misma forma.
3. No es un servicio monitoreado — se ejecuta manualmente, no en background.
4. Algunos usos de Console en el código implementan **enmascaramiento de contraseña** (sustitución por * caracter a caracter), lo que es técnicamente más seguro que un framework de logging que almacenaría el valor en archivos.

Recomendación

Estado: Falso Positivo (inaplicable a herramienta CLI)

Acción: Suprimir en dashboard de Kiuwan

Matriz de Hallazgos

Regla	Hallazgos CSV	CWE	Prioridad	Estado	Acción
<code>SensitiveInfoInConfigurationFile</code>	9	CWE-200	Normal	FP	Suprimir
<code>HardcodedCredential</code>	2	CWE-798	Normal	FP	Suprimir
<code>InformationExposureThroughDebugLog</code>	4	CWE-532	Baja	FP	Suprimir
<code>AvoidSystemOutputStream</code>	38	CWE-398	Baja	FP	Suprimir
Total	53			Todos Falsos Positivos	Suprimir

Conclusiones

1. **Cifrado de secretos** — El sistema implementa AES-256-CBC con gestión de clave maestra por variable de entorno. Los campos `BindPassword`, `DefaultPassword` y `DefaultConnection` están cifrados.
2. **Configuración LDAP** — `UserSearchBase` y `UserSearchFilter` son configuración estructural, no secretos. Ninguno contiene credenciales.
3. **Constantes de dominio** — Los valores de `CatalogGroups` y `GlobalVariables` son identificadores de negocio, no credenciales de seguridad.
4. **Logs de auditoría** — Registran operaciones de sincronización de catálogos en nivel Debug. No contienen datos sensibles ni de personas.
5. **Patrón CLI** — `SmartHubSecretTool` usa Console correctamente; la recomendación de la regla no aplica a herramientas interactivas de línea de comandos.

Recomendación final: Suprimir los 53 hallazgos en el dashboard de Kiuwan como falsos positivos confirmados.

Referencias

- CWE-200: Information Exposure — <https://cwe.mitre.org/data/definitions/200.html>
 - CWE-798: Use of Hard-coded Credentials — <https://cwe.mitre.org/data/definitions/798.html>
 - CWE-532: Insertion of Sensitive Information into Log File — <https://cwe.mitre.org/data/definitions/532.html>
 - CWE-398: Indicator of Poor Code Quality — <https://cwe.mitre.org/data/definitions/398.html>
 - RFC 4515: LDAP String Representation of Search Filters — <https://www.rfc-editor.org/rfc/rfc4515>
-

Documento técnico interno

Clasificación: Análisis de Seguridad

Generado: 2026-05-28